

Western Governors University
Legal Issues in Information Security

D828

Jessie Soto

QEN Task 2: SATE Program

A. Potential Ethical Challenges

TeleMedica is a global healthcare provider that connects patients with medical professionals through remote consultation solutions. One significant ethical issue is the risk of data interception during transmission. The organization is currently using SSL 2.0 to transport data, which is outdated and insecure with many vulnerabilities. This presents a serious concern because TeleMedica handles sensitive health information across international borders, including the United States, London, and Berlin. As a healthcare provider, it has a responsibility to safeguard patient privacy. Relying on weak encryption with known security flaws fails to adequately protect confidential data. If intercepted, large volumes of sensitive patient information could be exposed and misused.

A second ethical issue is the absence of clearly defined recovery time objectives (RTOs). An extended system outage could disrupt access to critical medical services. Because patients depend on these remote consultations for timely care, extended downtime could negatively impact their health and well-being.

B. Non-Compliance Consequences

Non-Compliance Consequence 1:

The first potential consequence the organization could face is a lack of transparency and accountability during a security incident. Its current incident response policy is vague and does not clearly define when affected individuals should be notified after a breach. Additionally, there is no clear guidance on how much information should be shared regarding the scope and potential impact of an incident. This lack of clarity can create distrust among customers and allow misinformation to spread, damaging the company's reputation.

Non-Compliance Consequence 2:

The second consequence of a potential data breach is the impact on thousands or even millions of patients whose sensitive information could be exposed. Such an incident could result in significant financial damage, including large-scale lawsuits. Legal action could also lead to regulatory fines, settlements, and substantial legal costs.

Non-Compliance Consequence 3:

The third consequence of a data breach is severe reputational damage among patients and service provider partners. Loss of trust could result in termination of business contracts, and long-term harm to the organization's competitive position.

C. Organizational Culture of Compliance Improvement

improvement 1:

The first proposed strategy for Telemedica to improve its compliance culture is to embed compliance directly into core business processes. Compliance considerations should be integrated into all new products, services, and major business decisions through mandatory compliance reviews before implementation. In addition, conducting regular compliance audits across departments can help identify compliance gaps.

Improvement 2:

A second way to strengthen compliance culture is by improving the reporting channels for ethical and security concerns. Encouraging employees to question existing practices and raise concerns can drive continuous improvement in both security controls and ethical standards. In addition, the organization should establish a clear and structured escalation process for reporting compliance concerns. This will help organization to promote transparency and continual improvement.

D. SATE Programs and Culture of Compliance

SATE Program Foster Cultural Compliance 1:

A SATE program can foster a strong culture of compliance by first bridging knowledge gaps through role-specific education. Each department should receive tailored

compliance training based on the types of data, systems, and processes they manage.

Rather than relying only on general awareness content, training should incorporate realistic, job-related scenarios that demonstrate the proper steps required to verify compliance in daily tasks. This approach will help employees understand how compliance applies to their specific responsibilities.

SATE Program Foster Cultural Compliance 2:

Another important component is visible leadership involvement. Leaders should actively participate in compliance training and pursue the same certifications to demonstrate accountability and commitment. Additionally, establishing a recognition program that celebrates employees who demonstrate exceptional compliance behavior helps reinforce positive actions. Together, these strategies create a continuous feedback loop that strengthens accountability, encourages engagement, and supports ongoing improvement in the organization's compliance culture.

E. SATE program Design

E1. SATE Program and Failures

SATE Address 1:

To address the failure to meet the HIPAA Security Rule regarding data-in-transit, the SATE program will implement specialized training for the IT infrastructure team. The current policy relies on the outdated and insecure SSL 2.0 protocol to encrypt data. The SATE program will educate the team on the latest protocols, such as TLS 1.2 or higher, which are

better for maintaining the confidentiality of sensitive health data during transmission.

Training will include realistic scenarios focused on securing data transmission by upgrading VPN protocols and ensuring the team is well-versed in the security and ethical laws, such as GDPR, HIPAA, and NIST standards.

SATE Address 2:

To address the issues related to NIST SP 800-63, the organization should begin by educating the entire workforce on the importance of strengthening cybersecurity through multifactor authentication (MFA). Currently, TeleMedica only requires employees to change their passwords every 90 days, which does not meet the recommended standards for stronger authentication controls such as MFA. The SATE program should focus on training all employees, especially those who handle sensitive data, on the importance of using MFA to protect systems and confidential information.

E2. SATE Proactive Security Measures

Proactive security measure 1: HIPPA security rule

To remediate the current use of the outdated SSL 2.0 protocol, the SATE program will proactively train the IT teams on transitioning to TLS 1.2 or higher. The current security policy will be updated to comply with GDPR, HIPAA, and NIST requirements for secure data transmission and will provide technical training to implement proper encryption controls that meet HIPAA Security Rule requirements. This will strengthen the organization's ability to protect and maintain the confidentiality of sensitive health information.

Proactive security measure 2: NIST SP 800-63

The SATE program will support a proactive transition from simple single-factor password authentication to a more secure multifactor authentication (MFA) model, as recommended by NIST SP 800-63. Currently, the security policy only requires passwords to be changed every 90 days, which presents a significant security weakness. By educating the workforce on the necessity of MFA and providing training on the use of biometric scanners or other authentication factors, the organization can significantly reduce the risk of unauthorized access, even in the event of a compromised password.

E3. Program Objectives

Proactive Objective for Security Measure 1:

With in 6 months of the SATE program implementation, the goal will be achieve 100% remediation of the insecure data transfer protocol by upgrading systems from the SSL 2.0 to the TLS 1.2 or higher protocol. The program will create training modules and workshops for the IT infrastructure department focusing on the configuration of TLS 1.2 or higher protocol.

Proactive Objective for Security Measure 2:

Within 30 days of program implementation, the goal is to achieve 100% adoption of multifactor authentication (MFA) across all systems in alignment with NIST SP 800-63 recommendations. The SATE program will provide training on MFA setup and proper usage.

It will also require the security team to configure conditional access requirements for system sign-on.

E4. Security Measure Key Topics

Key Topics for Security Measure 1:

Beginning with the current use of SSL 2.0, the training will explain why the SSL protocol is considered insecure, outline its known vulnerabilities, and discuss why it is ineffective for protecting protected health information (PHI). Next, the program will cover GDPR, HIPAA, and NIST compliance requirements related to securing data in transit.

Key Topics for Security Measure 2:

The first topic will be on the limitations and weakness of using a single factor authentication. This will include education on the risk of password only systems and common attacks against single factor authentication. The second topic will be practical instructions on how to use the MFA offered by the company. This will include a workshop on use the different types of MFA such as biometrics, hardware tokens and authenticator apps.

E5. Employee Actions

Employee Actions for Security Measure 1:

The IT infrastructure department must attend a hands-on training session on how to properly secure data transmission from local operations in the United States to the MediCom GmbH sister company in Berlin. They must demonstrate competency by successfully completing the training.

Employee Actions for Security Measure 2:

All employees and leaders must complete a short multifactor authentication (MFA) training module online provided by either the internal education department or a third-party provider. After completing the training, they will have 30 days to comply with the MFA requirements. Failure to do so will result in being unable to sign in, as the security team will enforce conditional access policies.

E6 Training Format

Formal Training Format Security Measure 1:

This will be an interactive simulation workshop. The IT infrastructure team will participate in simulations that mirror the actual configuration process of migrating from SSL to TLS 1.2 or higher. These simulations will be customized to reflect the specific data, systems, and network architecture currently used by TeleMedica. In addition, a compliance

workshop covering GDPR, HIPAA, and NIST requirements will be conducted to educate each role on the specific standards and controls that must be met.

Formal Training Format Security Measure 2:

This will be an online training module assigned to all employees and leaders across the organization. The module will begin by explaining why the company is implementing a more secure multifactor authentication (MFA) system. It will then cover the various types of MFA that TeleMedica will support. Next, it will include a video demonstration showing how to set up MFA, along with detailed documentation that provides a step-by-step guide for completing the setup process.

E7. Evaluation Metrics

Evaluation Metrics for Security Measure 1:

Success will be measured by tracking each system that previously used SSL 2.0 to verify that it has been upgraded to TLS 1.2 or higher. In addition, system log audits will be conducted to ensure that no data transmissions are occurring over SSL 2.0.

Evaluation Metrics for Security Measure 2:

Success will be evaluated by monitoring system logs to verify that 100% of logins require and use MFA.

F. Feedback and continuous improvement

Mechanism for Soliciting feedback for Continuous Improvement 1:

Following the SSL to TLS 1.2+ workshop, a short survey will be provided to each employee to assess the clarity of the technical instructions and the difficulty of understanding the new configuration concepts. This feedback will help identify pain points and areas where employees struggled with the material. The survey data will then be used to refine and improve the training module.

Mechanism for Soliciting feedback for Continuous Improvement 2:

In regard to MFA feedback for continual improvement, short surveys will be distributed monthly for approximately three months to measure how confident employees feel when using MFA tools. The survey results will then be cross-referenced with help desk tickets and system logs to identify trends and make necessary adjustments.

References :

zyBooks. (n.d.). *Section 11: [5.11 CASE STUDY (Part 1): Ethical issues]*. In *WGUD828v1, Chapter 5*. Retrieved February 23, 2026, from [Section 5.11 - D 828: Legal Issues in Information Security | zyBooks](#)

zyBooks. (n.d.). *Section 11: [4.11: Leading cybersecurity culture and awareness]*. In *WGUD828v1, Chapter 4*. Retrieved February 23, 2026, from [Section 4.11 - D 828: Legal Issues in Information Security | zyBooks](#)

zyBooks. (n.d.). *Section 5: [Title of section if available]*. In *WGUD828v1, Chapter 21*. Retrieved February 24, 2026, from [Section 21.5 - D 828: Legal Issues in Information Security | zyBooks](#)

Lando, M. (2019, June 20). *Developing a program plan and identifying resources needed* [Video]. LinkedIn Learning. [Developing a program plan and identifying resources needed - Building a Cybersecurity Awareness Program Video Tutorial | LinkedIn Learning, formerly Lynda.com](#)